

Отчет по выполнению индивидуального проекта. Этап №5

Основы информационной безопасности

Осман АлиНиколай

Содержание

1	Цель работы	5
2	Теоретическое введение	6
3	Выполнение лабораторной работы	7
4	Выводы	19
	Список литературы	20

Список иллюстраций

3.1	Запуск локального сервера	7
3.2	Запуск приложения	7
3.3	Сетевые настройки браузера	7
3.4	Настройки сервера	8
3.5	Настройки Burp Suite	9
3.6	Настройки Proxu	9
3.7	Настройки параметров	9
3.8	Получаемые запросы сервера	10
3.9	Страница авторизации	10
3.10	История запросов	11
3.11	Ввод случайных данных	11
3.12	POST-запрос с вводом пароля и логина	12
3.13	Вкладка Intruder	12
3.14	Изменение типа атаки	13
3.15	Первый Simple list	13
3.16	Второй Simple list	14
3.17	Запуск атаки	14
3.18	Результат запроса	15
3.19	Результат запроса	16
3.20	Дополнительная проверка результата	16
3.21	Вкладка Repeater	17
3.22	Окно Response	17
3.23	Изменение в окне Response	18
3.24	Полученная страница	18

Список таблиц

1 Цель работы

Научиться использовать Burp Suite.

2 Теоретическое введение

Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения. Эти инструменты позволяют сканировать, анализировать и использовать веб-приложения с помощью ручных и автоматических методов. Интеграция интерфейсов этих инструментов обеспечивает полную платформу атаки для обмена информацией между одним или несколькими инструментами, что делает Burp Suite очень эффективной и простой в использовании платформой для атаки веб-приложений. [parasram].

3 Выполнение лабораторной работы

Запускаю локальный сервер, на котором открою веб-приложение DVWA для тестирования инструмента Burp Suite (рис. [fig:001]).

```
(osmanalinikolai@osmanalinikolai)-[~]
$ sudo systemctl start apache2
[sudo] password for osmanalinikolai:
(osmanalinikolai@osmanalinikolai)-[~]
$ sudo systemctl start mysql
```

Рисунок 3.1: Запуск локального сервера

Запускаю инструмент Burp Suite (рис. [fig:002]).

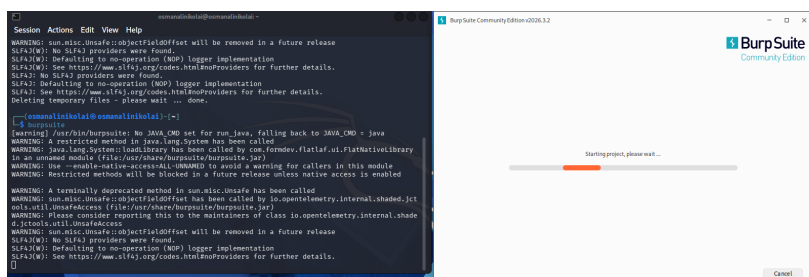


Рисунок 3.2: Запуск приложения

Открываю сетевые настройки браузера, для подготовке к работе (рис. [fig:003]).

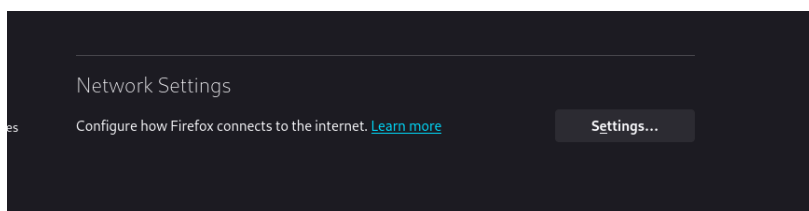


Рисунок 3.3: Сетевые настройки браузера

Изменение настроек сервера для работы с проху и захватом данных с помощью Burp Suite (рис. [fig:004]).

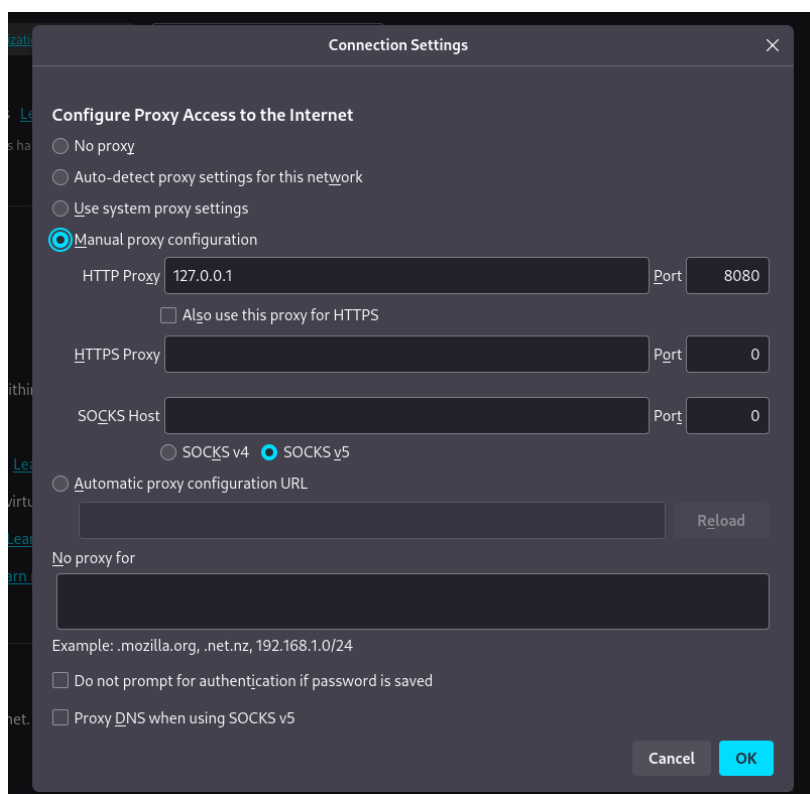


Рисунок 3.4: Настройки сервера

Изменяю настройки Проху инструмента Burp Suite для дальнейшей работы (рис. [fig:005]).

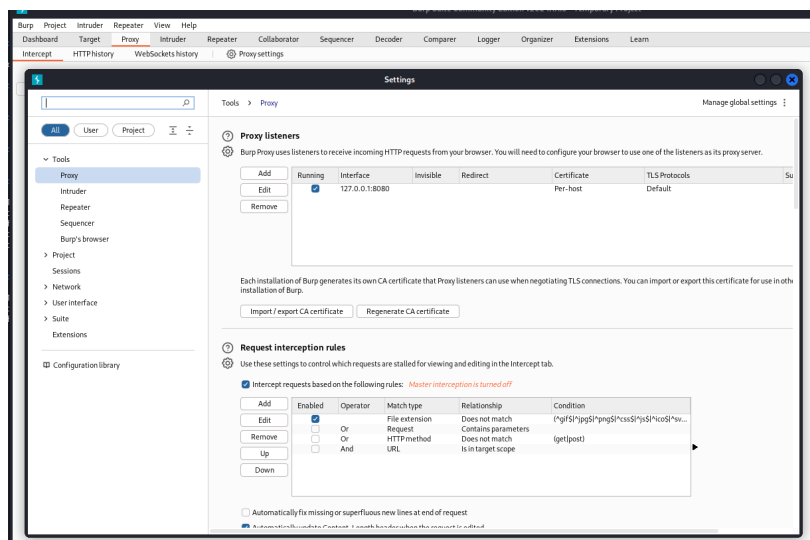


Рисунок 3.5: Настройки Burp Suite

Во вкладке Проxy устанавливаю «Intercept is on» (рис. [fig:006]).

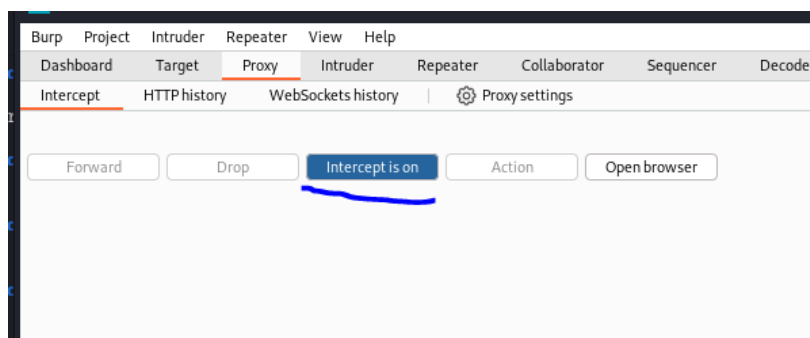


Рисунок 3.6: Настройки Проxy

Чтобы Burp Suite исправно работал с локальным сервером, необходимо установить параметр `network_allow_hijacking_localhost` на `true` (рис. [fig:007]).

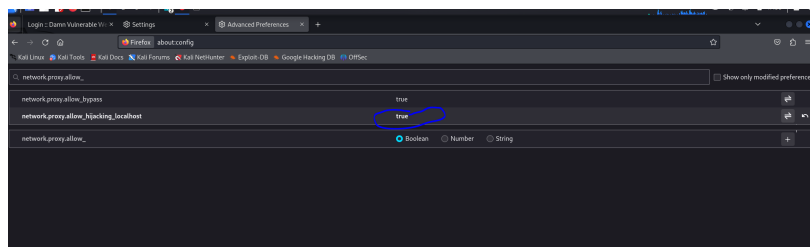


Рисунок 3.7: Настройки параметров

Пытаюсь зайти в браузере на DVWA, тут же во вкладки Проху появляется захваченный запрос. Нажимаем «Forward», чтобы загрузить страницу (рис. [fig:008]).

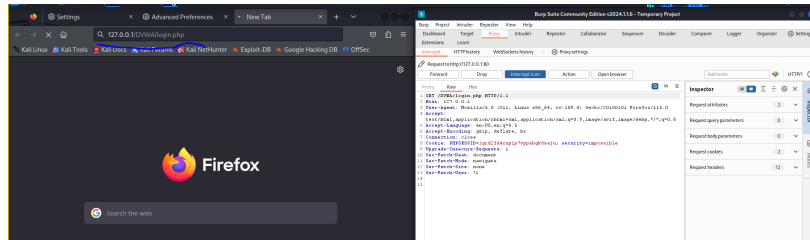


Рисунок 3.8: Получаемые запросы сервера

Загрузилась страница авторизации, текст запроса поменялся (рис. [fig:009]).

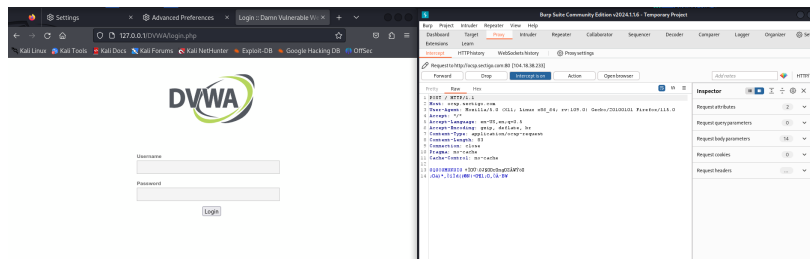


Рисунок 3.9: Страница авторизации

История запросов хранится во вкладке Target (рис. [fig:010]).

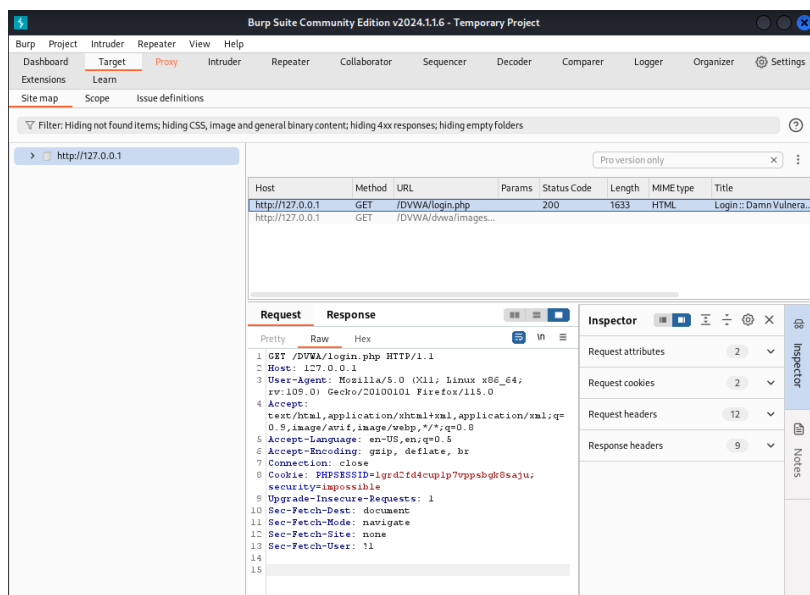


Рисунок 3.10: История запросов

Попробуем ввести неправильные, случайные данные в веб-приложении и нажмем Log in. В запросе увидим строку, в которой отображаются введенные нами данные, то есть поле для ввода (рис. [fig:011]).

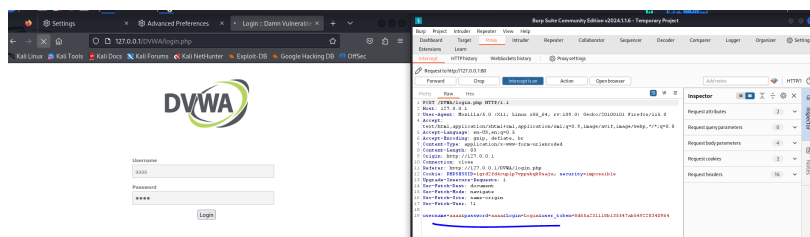


Рисунок 3.11: Ввод случайных данных

Этот запрос так же можно найти во вкладке Target, там же жмем правой кнопкой мыши на хост нужного запроса, и далее нажимаем «Send to Intruder» (рис. [fig:012]).

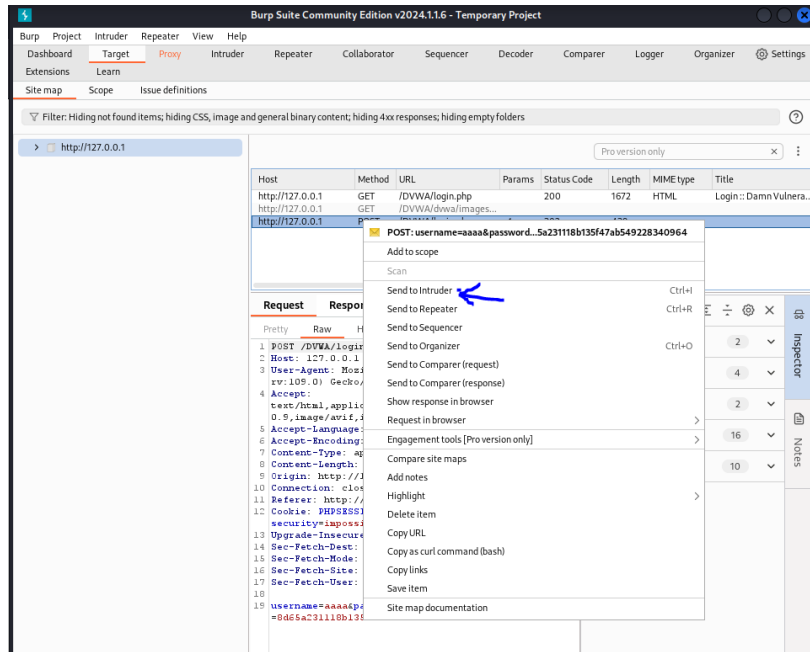


Рисунок 3.12: POST-запрос с вводом пароля и логина

Попадаем на вкладку Intruder, видим значения по умолчанию у типа атаки и наш запрос (рис. [fig:013]).

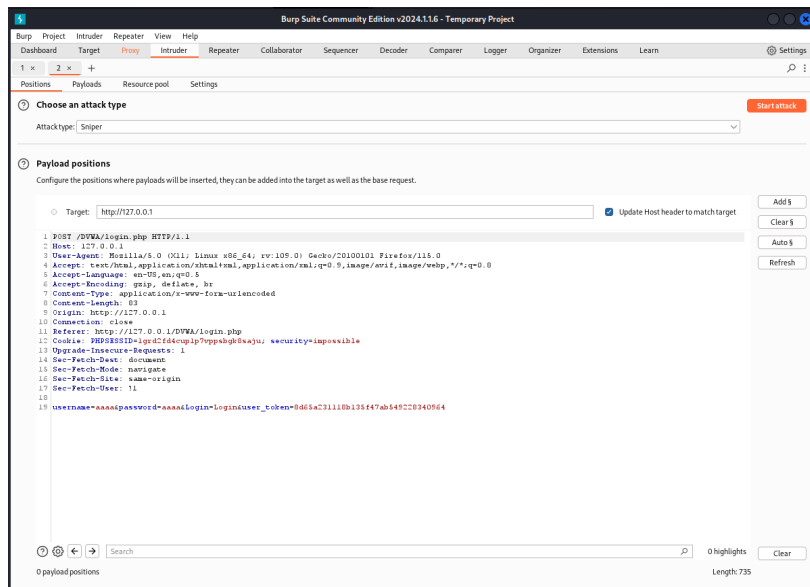


Рисунок 3.13: Вкладка Intruder

Изменяем значение типа атаки на Cluster bomb и проставляем специальные

символы у тех данных в форме для ввода, которые будем пробовать, то есть у имени пользователя и пароля (рис. [fig:014]).

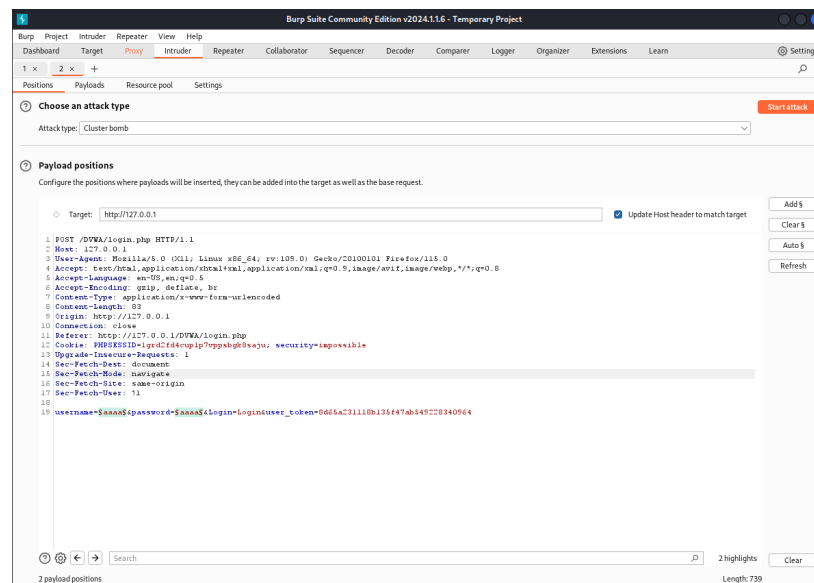


Рисунок 3.14: Изменение типа атаки

Так как мы отметили два параметра для подбора, то нам нужно два списка со значениями для подбора. Заполняем первый список в Payload setting (рис. [fig:015]).

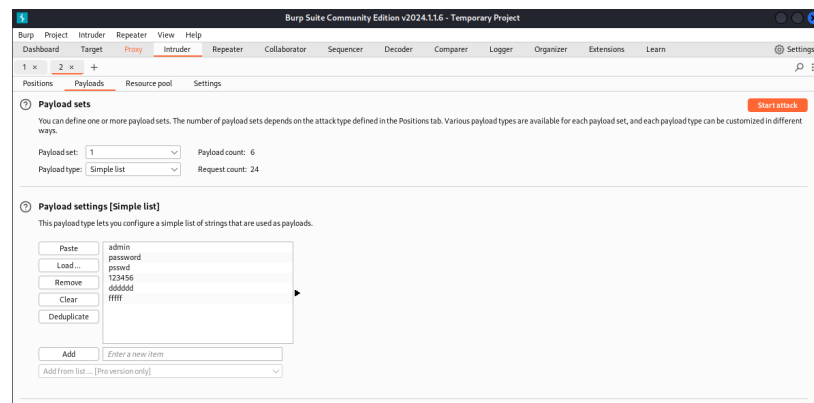


Рисунок 3.15: Первый Simple list

Переключаемся на второй список и добавляем значения в него. В строке request count видим нужное количество запросов, чтобы проверить все возможные пары

пользователь-пароль (рис. [fig:016]).

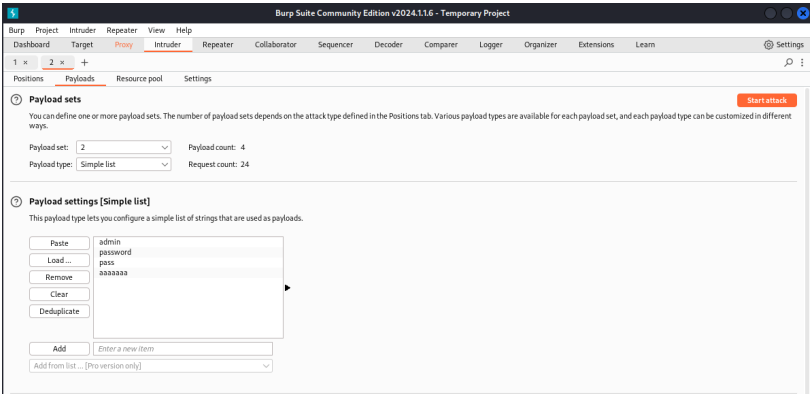


Рисунок 3.16: Второй Simple list

Запускаю атаку и начинаю подбор (рис. [fig:017]).

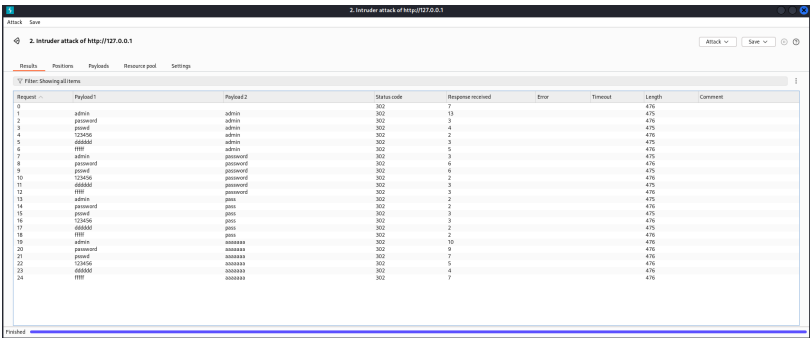


Рисунок 3.17: Запуск атаки

При открытии результата каждого post-запроса можно увидеть полученный get-запрос, в нем видно, куда нас перенаправило после выполнения ввода пары пользователь-пароль. В представленном случае с подбором пары admin-admin нас перенаправило на login.php, это значит, что пара не подходит (рис. [fig:018]).

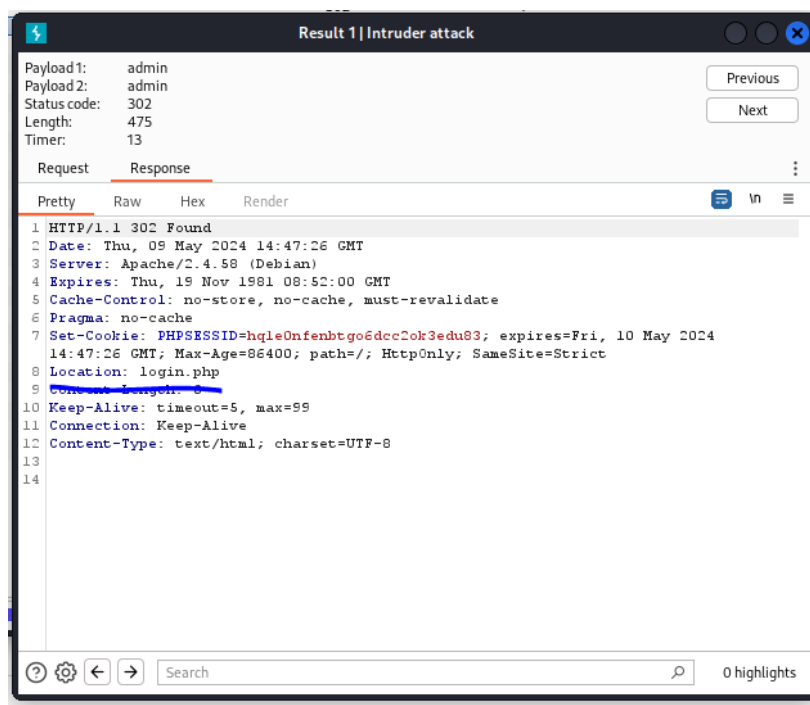


Рисунок 3.18: Результат запроса

Проверим результат пары admin-password во вкладке Response, теперь нас перенаправляет на страницу index.php, значит пара должна быть верной (рис. [fig:019]).

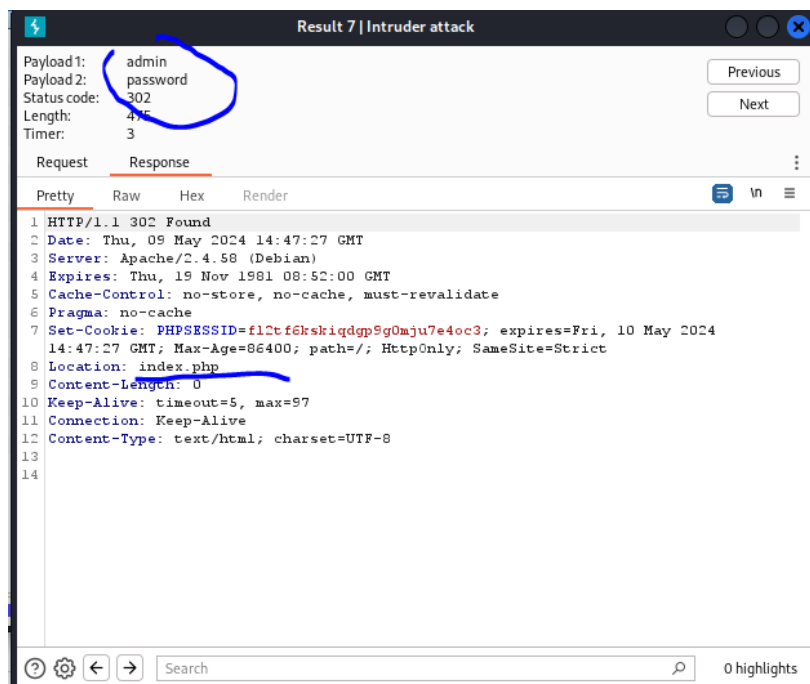


Рисунок 3.19: Результат запроса

Дополнительная проверка с использованием Repeater, нажимаем на нужный нам запрос правой кнопкой мыши и ждем «Send to Repeater» (рис. [fig:020]).

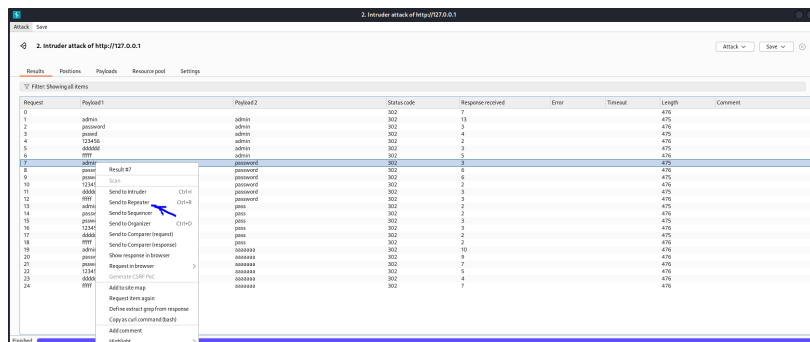


Рисунок 3.20: Дополнительная проверка результата

Переходим во вкладку «Repeater» (рис. [fig:021]).

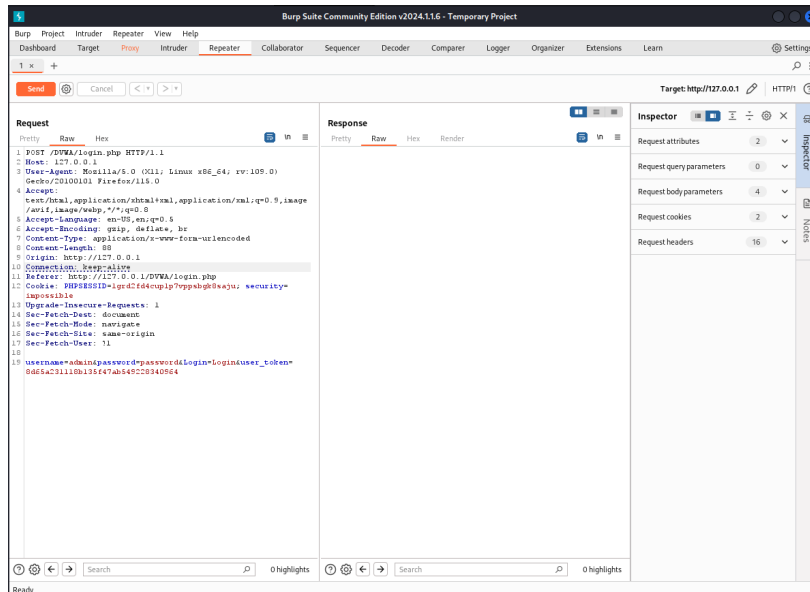


Рисунок 3.21: Вкладка Repeater

Нажимаем «send», получаем в Response в результат перенаправление на `index.php` (рис. [fig:022]).

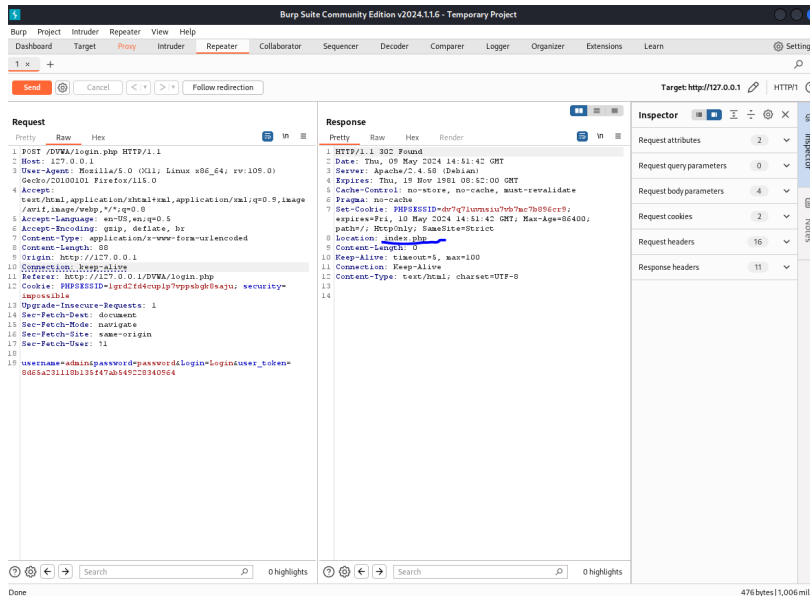


Рисунок 3.22: Окно Response

После нажатия на `Follow redirection`, получим неcompiled html код в окне Response (рис. [fig:023]).

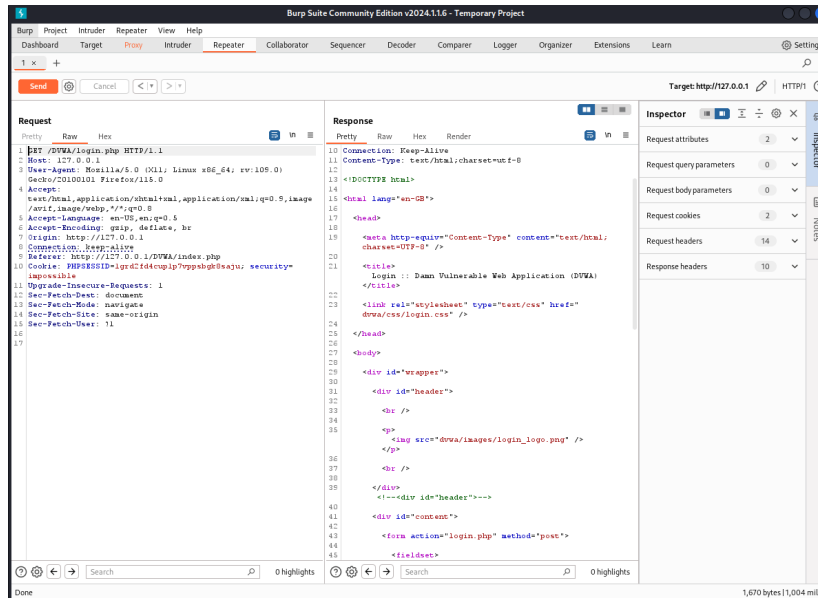


Рисунок 3.23: Изменение в окне Response

Далее в подокне Render получим то, как выглядит полученная страница (рис. [fig:024]).

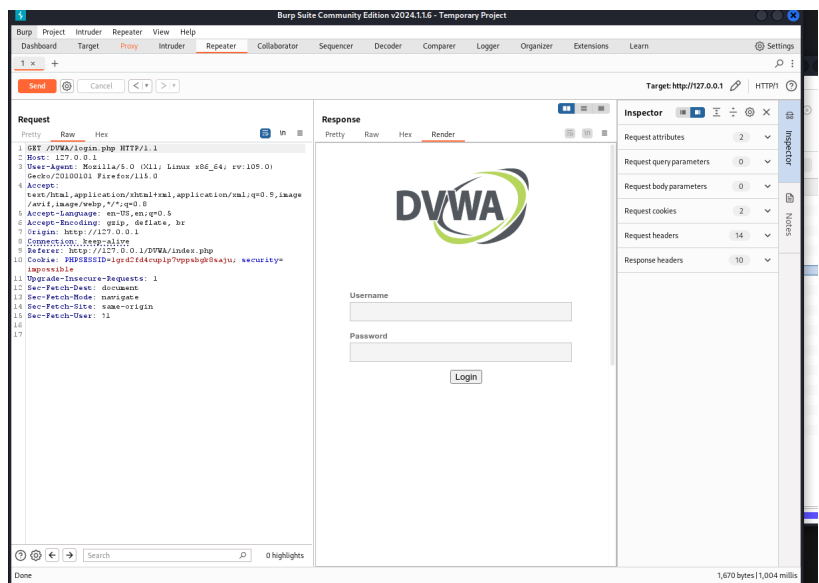


Рисунок 3.24: Полученная страница

4 Выводы

При выполнении лабораторной работы научился использовать инструмент Vigr Suite.

Список литературы